

6 Detect Anomalous Activity to Systems or Transaction Records

6.1 Malware Protection

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
<u>Control Definition</u> Control Objective: Ensure that the user's Swift infrastructure is protected against malware and act upon results. In-scope components: Malware protection is implemented for Windows operating systems of the below components: - dedicated and general-purpose operator PC - jump server - management PCs of an on-premises or remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform - systems hosting a Swift-related components (including interface, GUI, Swift or customer (client) connector) - bridging servers (such as middleware or file transfer servers other than customer connectors) used for and guardian of the secure data exchange between back-office and Swift-related components [Advisory: Malware protection is implemented, when technically possible and proportioned to the risk exposure, for non-Windows operating systems (i) hosting a customer client connector or (ii) located within a secure zone and hosting a Swift-related component, a jump server or a dedicated operator PC] Risk Drivers: - execution of malicious code - exploitation of known security vulnerabilities						
<u>Implementation Guidance</u> Control Statement: Anti-malware software from a reputable vendor is installed, kept up-to-date on all systems, and results are considered for appropriate resolving actions. An Endpoint Protection Platform (EPP) solution, combined or not with Endpoint Detection and Response (EDR), offering similar control on the infrastructure can be considered as a valid implementation. Control Context: Malware is a general term that includes many types of intrusive and unwanted software, including viruses. Anti-malware technology (a broader term for anti-virus) or other endpoint protection mechanisms are effective in protecting against malicious code. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). On-access anti-malware scanning (also known as real-time or background scanning) is performed on all in-scope systems. On-demand full scanning is scheduled at least on a weekly basis for operator PCs (ideally on a daily basis). On-demand full scanning should be scheduled regularly for servers in line with business and operational constraints. For performance reasons full scans are performed at times of low usage, outside of business hours, or both.						

- The scope of the scanning should include all files of the systems in scope. Exclusion of elements or directory from scanning is subject to risk assessment considering user's infrastructure set-up, internal security requirements and policies, the product capabilities and the following principles:
 - Software (such as exe, libraries, scripts) and static data (such as configuration files) are expected to be scanned on-access or at installation, and regularly thereafter, when complemented with a run-time integrity mechanism (in line with the software integrity check depicted in control 6.2) allowing the identification of file changes or unexpected additions.
 - Database server content (data files) can be excluded from the scanning when the data has been checked, validated, and scanned at least once before being stored.
- Anti-malware software from a reputable vendor is installed on all computing platforms and updated in line with the scanning frequency.
- Systems that fail to update their profiles or run scheduled scans are detected and corrected.
- Anti-malware software is tested for compatibility with the operational environment.
- Anti-malware software is configured in prevent mode if possible, after assessing for operational impact. It is recommended to configure the anti-malware software to quarantine suspicious files and to raise an alarm to the user's security department instead of immediately deleting them. This enables the user's security department to investigate the alert and possibly prevent future 'false positives' while allowing the recovery of files if it is confirmed that they are legitimate.
- Files to be sent should be scanned at least once at any stage/step of their internal processing and, ideally, as close as possible to their transfer into the Swift network. This is to make sure that such files do not contain viruses or malware that may create risks for the sender, for Swift, or for the receiver.
- Endpoint Protection Platform (EPP) solution, combined or not with Endpoint Detection and Response (EDR) offering similar control on the infrastructure can be considered as a valid implementation.
- The resulting alerts are analysed for appropriate action and remediation in line with or as part of control the 6.4.

Optional Enhancements:

- Anti-malware systems use a combination of signature-based and heuristic-based capabilities.
- Anti-malware or other EPP solutions are implemented, when technically possible, on all General-purpose operator PCs.
- Anti-malware solutions are, when technically possible, implemented on all non-Windows systems.
- 'On-demand full scanning' on servers is scheduled to be performed at least on a weekly basis.